We collect only what the advice or the sale needs, never sell data, and never send a farmer's identity to the AI. Farmers can download or delete their data from the app at any time.

What data, why, where, who can see it

DATA	WHY	STORED WHERE	WHO CAN SEE IT	HOW LONG
Crop photo for a check	To find the problem	**Not stored.** Sent once to the AI (Google Gemini) with the crop name only	Nobody at AgriAI	Not kept by us
Check results ("मेरी जाँच")	History, follow-up	Database (planned: MongoDB Atlas, Mumbai)	The farmer's own phone	Until the farmer deletes
Farm profile (village, crops, sowing date)	Local weather & water advice	Database, linked to an anonymous phone ID	The farmer	Until deleted
Account (name, phone, village, UPI ID)	Buying and selling	Database; PIN only as a bcrypt hash	The person; the other party of an order sees name/phone; SHG coordinator	Until deleted
Sale listing photos	Show the produce	Photo storage (Cloudinary planned)	Everyone in the market	Until the listing/account is deleted
Orders and commission	Accounting	Database	Buyer, seller, coordinator	Kept for accounts, **without** name, village or address after deletion
Usage counts (pilot dashboard)	Measure the pilot	Database, weekly pseudonym, fixed values only	Coordinators (counts, no names)	400 days, then auto-deleted
Consent record	Proof of consent	Database (version, time, language)	—	Until deleted

Farmer's rights in the app (DPDP basics)

- **Consent first:** simple Hindi consent screen with 🔊, before any data is used; asked again when the text changes.
- **"मेरा डेटा":** download everything as a file, or delete it at once (two confirmations). Completed orders are anonymised, not deleted.
- **Complaints:** in-app complaint queue, coordinator answers within 48 hours.
- India's DPDP Rules, 2025 were notified on 14 Nov 2025 with an 18-month phased compliance timeline and rights to access, correct and erase data [S5]. Our privacy policy and terms are **drafts awaiting legal review**.

What the AI receives

- Photo check: **only the photo and the crop name** (tested automatically).
- Follow-up chat: crop, the earlier answer and the questions – never the photo or phone ID.
- Selling: the product photo and the seller's words with phone numbers removed.

Security controls (built)

- HTTPS only; login cookie HttpOnly, SameSite=Strict, Secure.
- PIN lockout after 5 wrong tries (15 min); rate limits on every API.
- Strict Content-Security-Policy, helmet headers, every input validated.
- Server checks every role and ownership (a seller can only change own listings; delivery links expire after 14 days or on delivery).
- **Audit log:** every coordinator action (who, what, when) – append-only, cannot be edited or deleted.
- Logs hide PIN, tokens, phone numbers and photos; error reports (optional) carry no user data.
- **Backups:** daily, encrypted, kept 14 days (GitHub Actions or server cron; restore script included).
- No known vulnerable packages (`npm audit`: high = 0); dependencies kept minimal.

Open items (honest)

- Legal review of policy, terms, consent text and retention.
- Hosting not yet live; server region planned Singapore (Render), database Mumbai (Atlas).
- Google processes photos under its API terms; a government-hosted model can be connected if required.
- No external security audit yet – welcome before scale-up.

[S5] PIB/MeitY 14 Nov 2025 – see showcase/SOURCES.md